信息安全测评与风险评估

7.3.2 物联网安全配置核查

授课教师：张玉



目录

CONTENTS

01 案例导入——被直播的卧室：摄像头弱口令

02 学习目标与标准定位

03 物联网安全配置核查六大维度

04 物联网安全测评实践与案例

案例导入——被直播的卧室：摄像头弱口令入侵



案例素材

2017年，大量家用摄像头因出厂默认口令被入侵，卧室、客厅画面在黑产群被标价售卖、甚至“直播”。设备本身没有漏洞——默认口令没改、固件没更新、远程访问大开，三道门全开着。

摄像头、智能门锁、传感器——这些“小东西”，测评时到底该查什么？

案例讨论：问题出在哪

思考

- 问题出在“漏洞”，还是“配置”？
- 设备本身没有漏洞，攻破它只因为：默认口令没改、固件没更新、远程访问大开。
- 这三件事，正好是物联网安全配置核查的第一批检查项。

学习目标

通过本课学习，你将能够：

01 理解

物联网安全扩展要求与安全通用要求的关系

02 掌握

物联网安全配置核查的核心测评指标（感知节点物理防护、接入控制、入侵防范、感知节点安全、网关节点安全、抗数据重放）

03

能够依据GB/T 22239物联网扩展要求进行安全配置核查

04

能够规范填写《物联网安全测评记录表》

物联网安全扩展要求——在等保中的位置

等保定位：GB/T 22239-2019 在通用要求之外，为物联网单列了一组“安全扩展要求”。三层架构已在 7.3.1 建立，这一课只回答一个问题：每一项要求落在哪一层、怎么查。

逻辑层	测评对象	安全要求来源
感知层	感知节点、网关节点（设备本体）	物联网安全扩展要求（重点）
网络传输层	无线接入与承载链路	安全通用要求（通信网络、区域边界）
处理应用层	云平台与业务应用	安全通用要求（计算环境）

关键认识：物联网安全测评 = 安全通用要求 + 物联网安全扩展要求

物联网安全扩展要求的六个维度

第三级物联网安全扩展要求涵盖以下六个方面：

1 感知节点设备物理防护

核心关注点：物理破坏防护、环境适应性、电力供应**测评对象：**感知节点、网关节点

2 接入控制

核心关注点：只有授权的感知节点可以接入**测评对象：**感知节点、接入机制

3 入侵防范

核心关注点：限制通信目标地址，避免对陌生地址攻击**测评对象：**感知节点、网关节点

4 感知节点设备安全

核心关注点：授权配置、身份标识和鉴别**测评对象：**感知节点、网关节点

5 网关节点设备安全

核心关注点：合法设备标识鉴别、非法数据过滤、密钥在线更新**测评对象：**网关节点

6 抗数据重放

核心关注点：数据新鲜性鉴别、历史数据非法修改鉴别**测评对象：**感知数据、通信协议

维度一——感知节点设备物理防护

依据：GB/T 22239 8.4.1.1

测评指标及核查要点

指标类型	核查要点要求	测评方法
物理破坏防护	感知节点所处物理环境不应对设备造成物理破坏（挤压、强振动等）	现场检查部署环境，查阅验收文档
环境状态反映	感知节点在工作状态所处物理环境应能正确反映环境状态（如温湿度传感器不能安装在直射区）	现场核查安装位置是否合理
正常工作环境	感知节点所处物理环境不应影响其正常工作（强干扰、阻挡屏蔽等）	核查是否有防干扰、防屏蔽措施
电力供应	关键感知节点设备应具有可供长时间工作的电力供应；关键网关节点应具有持久稳定电力供应	检查供电方式、UPS配置、电力维护记录

常见避坑提示

- ✕ **传感器安装在阳光直射区域**
  → 温度读数偏差
- ✕ **室外设备无防护箱体**
  → 日晒雨淋导致设备故障
- ✕ **关键监控节点无UPS供电**
  → 断电后监控失效

维度二——接入控制

依据 / 测评指标

GB/T 22239 8.4.2.1：授权接入

核心核查要点

保证只有授权的感知节点可接入

核心测评方法

核查设备身份鉴别机制（如编码、证书、MAC白名单等）

具体核查要点

- 感知节点具有唯一身份标识（如设备ID/MAC绑定）
- 接入时进行身份校验（如密钥、数字证书）
- 建立合法设备白名单

测试方法

尝试用非授权设备接入传感网，验证是否被拒绝。

维度三——入侵防范

依据：GB/T 22239 8.4.2.2

测评指标

a 限制感知节点

应能够限制与感知节点通信的目标地址，避免对陌生地址的攻击；需登录感知节点查看配置并测试。

b 限制网关节点

应能够限制与网关节点通信的目标地址，避免对陌生地址的攻击；需登录网关节点查看配置并测试。

核查要点

- 感知节点是否配置了允许通信的白名单
- 网关节点是否配置了通信目标地址控制措施
- 是否能防止感知节点攻击外部陌生地址

测试方法

尝试让感知节点向非授权地址发送数据，验证是否被拦截。